

CVEs más relevantes de la semana

Del 04/07/2026 al 11/07/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-14535

Descripción: In Trail of Bits fickling versions up to and including 0.1.11, the UnsafeImportsML analysis pass unconditionally calls `AnalysisContext.shorten_code(node)` on every import node it inspects, regardless of whether the import is flagged as unsafe. This call registers the shortened code representation in the shared `AnalysisContext.reported_shortened_code` set. When the `MLAllowlist` analysis pass subseq...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-04



CVE-2026-40139

Descripción: A critical pre-authentication vulnerability exists in the authentication subsystem of BeyondTrust Remote Support. Improper processing of authentication requests may allow an unauthenticated remote attacker to bypass access controls and gain unauthorized access to the appliance, including accounts with elevated privileges. Exploitation requires a specific authentication configuration to be enabled.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-07-06



CVE-2026-40141

Descripción: A high-severity vulnerability exists in a web application component of BeyondTrust Remote Support and Privileged Remote Access related to the processing of certain input parameters. Insufficient validation of user-supplied input may allow an authenticated attacker with limited privileges to access unintended resources or data beyond their authorization scope. Exploitation is restricted to accou...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-943

Tecnología: No especificado

Publicado el: 2026-07-06



CVE-2026-54763

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to v2.11.51, v3.6.22, and v3.7.6, Traefik's BasicAuth, DigestAuth, and ForwardAuth middlewares strip canonical-cased spoofed identity headers before writing Traefik's own value, but do not account for underscore-variant header names, which many backends normalize identically to dashed forms. An attacker able to reach a protected route ca...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-178

Tecnología: No especificado

Publicado el: 2026-07-06



CVE-2026-13020

Descripción: A Weak Password Recovery Mechanism for Forgotten Password exists in Esri Portal for ArcGIS versions 12.1 and earlier on Windows, Linux and Kubernetes. A remote, unauthorized attacker may assume ownership of a user's account by manipulating this mechanism. ArcGIS Administrators should configure an email server with ArcGIS Enterprise to facilitate user self-service password recovery. The ability ...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-640

Tecnología: No especificado

Publicado el: 2026-07-07



CVE-2026-60002

Descripción: ssh in OpenSSH before 10.4 can have a use-after-free when a server changes its host key during a key re-exchange. (This outcome occurs only on the client side.)

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-58480

Descripción: Blocksy Companion Pro plugin for WordPress before 2.1.47 contains an unauthenticated arbitrary file upload vulnerability that allows attackers to upload executable files by bypassing extension validation in the `save_attachments` function exposed through the Advanced Reviews feature. Attackers can exploit the Custom Fonts extension's flawed `strpos()` substring check by uploading double-extension f...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-3144

Descripción: IBM API Connect 12.1.0.0 through 12.1.0.3 uses default credentials which could allow an attacker to gain unauthorized access to the application before the system enforces a credential update.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-9074

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.9 and 12.1.0.0 through 12.1.0.3 contains an unauthenticated SQL injection vulnerability in the password reset functionality.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-8649

Descripción: Improper Neutralization of Special Elements in Data Query Logic vulnerability in Progress MOVEit Transfer (Custom Reports modules).

This issue affects MOVEit Transfer: before 2025.0.7, from 2025.1.0 before 2025.1.3.

CVSS: 6.4 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-943

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-8801

Descripción: Path equivalence: vulnerability in Progress MOVEit Transfer (File Upload modules).

This issue affects MOVEit Transfer: before 2025.0.8, from 2025.1.0 before 2025.1.4.

CVSS: 3.5 (LOW)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:N/I:L/A:N

Tipo: CWE-46

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-56291

Descripción: The Joomla extension Balbooa Forms is vulnerable to an unauthenticated arbitrary file upload that allows uploading executable files and leads to full RCE.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-59214

Descripción: Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. Prior to 0.10.0, Open WebUI runs client-side Python with Pyodide in a same-origin web worker, allowing stored chat payloads that use `pyodide.http.pyfetch` or the `js` module `fetch` and `XMLHttpRequest` APIs to issue authenticated same-origin requests when a victim clicks Run, which can reach admin-only endpoints and...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-15282

Descripción: The Instant Appointment plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'insapp_upload_image_as_attachment' function in all versions up to, and including, 1.2. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-15378

Descripción: A flaw was found in the 'guardrails-detectors' component. This vulnerability allows a remote attacker to perform a blind Server-Side Request Forgery (SSRF) by submitting a specially crafted XML Schema Definition (XSD) string. This can lead to unauthorized access to sensitive information, including credentials from cloud metadata services, Kubernetes API, internal MinIO, and other internal netwo...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-59792

Descripción: In JetBrains IntelliJ IDEA before 2026.1.4, 2026.2 code execution via path traversal in project workspace ID handling was possible

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:L

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-61459

Descripción: MCP Server Kubernetes before 3.9.0 contains an argument injection vulnerability in structured tools (kubectl_get, kubectl_describe, kubectl_delete) that allows attackers to bypass the assertNoDangerousFlags security check by supplying resourceType and name parameters with leading dashes. Attackers can inject the --server flag to redirect kubectl commands to an attacker-controlled API server, ca...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-88

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-12761

Descripción: The miniOrange Social Login and Register (Discord, Google, Twitter, LinkedIn) plugin for WordPress is vulnerable to authentication bypass leading to account takeover in versions up to and including 7.7.0. This is due to the Profile Completion flow accepting an arbitrary email address via the 'email_field' POST parameter without verifying that the email belongs to the identity returned by the OA...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-07-10



Resumen del Reporte

CVEs analizados: 18

Promedio CVSS: 8.70

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

